Theory Note 6 of 8

Fifteen Key Windows Security Event IDs

Network Traffic Analysis, Nmap and Windows Logging | Week 2

1. Overview

Windows can write thousands of different events, but a small group of Security log event IDs covers most of what an analyst needs: who logged on, who failed to, what was run, which accounts changed, and whether anyone tried to hide it. The table gives the meaning of each and the situation in which it is most useful.

2. The fifteen event IDs

Event ID	Meaning	When to use it
4624	An account was successfully logged on	To confirm who logged in, from where and by which logon type. Watch for odd hours, or type 3 and type 10 from new IP addresses.
4625	An account failed to log on	To detect brute force and password spraying: many failures for one account, or one failure each for many accounts. Check the status and sub-status codes.
4634	An account was logged off	To work out how long a session lasted. Match it to 4624 using the Logon ID.
4648	A logon was attempted using explicit credentials	To catch runas, mapped drives or lateral movement where someone supplies another account's credentials.
4672	Special privileges assigned to a new logon	To identify administrator-level logons and unexpected accounts receiving powerful privileges.
4688	A new process was created	To track what ran on a host. With command-line auditing on, it shows the exact command (PowerShell, cmd, certutil).
4697	A service was installed on the system	To find persistence or lateral movement through new services, as PsExec-style tools do.
4720	A user account was created	To spot backdoor or rogue accounts, and to see who created them.
4722	A user account was enabled	To notice a dormant or disabled account being brought back into use.
4724	An attempt was made to reset an account's password	To investigate possible account takeover when someone other than the owner resets a password.
4732	A member was added to a security-enabled local group	To detect privilege escalation, such as a user being added to Administrators.
4768	A Kerberos authentication ticket (TGT) was requested	To follow domain logons and to spot AS-REP roasting or unusual ticket requests.
4769	A Kerberos service ticket was requested	To detect Kerberoasting (many requests, often with weak RC4 encryption) and to track access to services.
4776	The computer attempted to validate credentials for an account (NTLM)	To review NTLM logons and failures, which can point to pass-the-hash or password spraying on a domain controller.
1102	The audit log was cleared	To catch anti-forensics. Someone is covering their tracks, so always investigate.

3. Notes

- Events 4624 and 4625 contain a Logon Type field, covered in the next note.

- Event 1102 is written to the Security log. When other logs are cleared, the System log records event 104 instead.
- Event 7045 in the System log records a newly installed service. It is part of the lab work and is seen when running sc create.
- Command-line details in 4688 only appear if the audit policy 'Include command line in process creation events' is enabled.

> **Key takeaway**
> Five events tell most of a compromise story: 4625 (failed logon), 4624 (successful logon), 4688 (process created), 4720 and 4732 (account created and made admin), and 1102 (log cleared).